NAJWYŻSZA IZBA KONTROLI

Realizacja przez podmioty państwowe zadań w zakresie ochrony cyberprzestrzeni RP

Podsumowanie wyników kontroli planowej NIK nr P/14/043

Warszawa, 14 października 2015 r.

Cel kontroli

Sprawdzenie, w jaki sposób administracja państwowa zarządza ryzykiem związanym z zagrożeniami występującymi w cyberprzestrzeni RP, tj. w szczególności:

- **Czy został opracowany spójny system działań organów administracji państwowej, mający na celu monitorowanie zagrożeń występujących w cyberprzestrzeni RP, przeciwdziałanie im oraz minimalizowanie skutków incydentów?**
- **Czy określono ramy prawne tego systemu, dokonano podziału kompetencji między jego uczestnikami, przydzielono im niezbędne zasoby oraz określono mechanizmy koordynacji i wymiany informacji?**

Zakres kontroli: podmioty i okres czasowy

Kontrolą objęto:

- Ministerstwo Administracji i Cyfryzacji;
- Ministerstwo Spraw Wewnętrznych;
- Agencję Bezpieczeństwa Wewnętrznego;
- Ministerstwo Obrony Narodowej;
- Urząd Komunikacji Elektronicznej;
- Rządowe Centrum Bezpieczeństwa;
- Komendę Główną Policji;
- Naukową i Akademicką Sieć Komputerową.

Okres objęty kontrolą: lata 2008-2014

Ogólna ocena kontrolowanej działalności

Najwyższa Izba Kontroli oceniła negatywnie realizację zadań w zakresie ochrony cyberprzestrzeni RP.

Administracja państwowa nie podjęła niezbędnych działań, mających na celu zapewnienie bezpieczeństwa teleinformatycznego Polski.

Pomimo tego, że coraz większa część usług publicznych oraz istotnych aspektów życia społecznego i gospodarczego realizowanych jest w sieci Internet lub z wykorzystaniem systemów teleinformatycznych, bezpieczeństwo Polski w dalszym ciągu jest postrzegane jedynie w sposób konwencjonalny.

Ogólna ocena kontrolowanej działalności cd.

Nie został zorganizowany system ochrony cyberprzestrzeni RP. Działania państwa w zakresie bezpieczeństwa teleinformatycznego sprowadzały się do doraźnego, ograniczonego reagowania na bieżące wydarzenia oraz biernego oczekiwania na rozwiązania, które zaproponuje Unia Europejska.

Kluczowym czynnikiem paraliżującym aktywność państwa w tym zakresie był brak jednego ośrodka decyzyjnego, koordynującego działania innych instytucji publicznych oraz niewystarczające zaangażowanie najwyższego kierownictwa administracji rządowej, w tym w szczególności Prezesa Rady Ministrów.

Główne ustalenia kontroli

1. **Kierownictwo większości objętych kontrolą podmiotów nie miało świadomości należących do nich zadań związanych z ochroną cyberprzestrzeni RP:**

„(…) uprzejmie informuję, że (…) w ustawowych zadaniach Kancelarii Prezesa Rady Ministrów brak jest zadań związanych bezpośrednio z bezpieczeństwem cyberprzestrzeni RP (…)”

Główne ustalenia kontroli

Prezes Rady Ministrów → Minister Administracji i Cyfryzacji

Minister Administracji i Cyfryzacji → Minister Spraw Wewnętrznych, Szef ABW, Dyrektor RCB, Prezes UKE

Minister Administracji i Cyfryzacji ← Minister Spraw Wewnętrznych, Szef ABW, Dyrektor RCB, Prezes UKE

Główne ustalenia kontroli cd.

2. **Rada Ministrów i kierownictwo podmiotów administracji państwowej nie opracowały narodowej strategii ochrony cyberprzestrzeni Polski, która mogłaby być podstawą konkretnych, systemowych działań podnoszących poziom bezpieczeństwa teleinformatycznego państwa.**

   Siedem kolejnych projektów ww. strategii opracowanych w latach 2008-2012 nie zostało zatwierdzonych. Dopiero w czerwcu 2013 r. przyjęto „Politykę ochrony cyberprzestrzeni Rzeczypospolitej Polskiej" – dokument będący wynikiem braku porozumienia i źle rozumianego kompromisu, nieprecyzyjny i obarczony błędami merytorycznymi, uniemożliwiającymi jego praktyczne zastosowanie.

Główne ustalenia kontroli cd.

3. Nie zostało przeprowadzone kompleksowe oszacowanie ryzyk związanych ze zdarzeniami występującymi w cyberprzestrzeni.

4. Nie były prowadzone prace legislacyjne mające na celu unormowanie zagadnień związanych z bezpieczeństwem teleinformatycznym. Obowiązujące przepisy były rozproszone, nieprecyzyjne lub też w ogóle nie stosowane w praktyce.

Główne ustalenia kontroli cd.

5. Nie stworzono systemu finansowania działań związanych z ochroną cyberprzestrzeni RP. Brak adekwatnych zasobów sparaliżował działania państwa w tym zakresie.

6. Działania w zakresie ochrony cyberprzestrzeni były prowadzone w sposób niespójny, bez rzetelnego planowania i przygotowania.

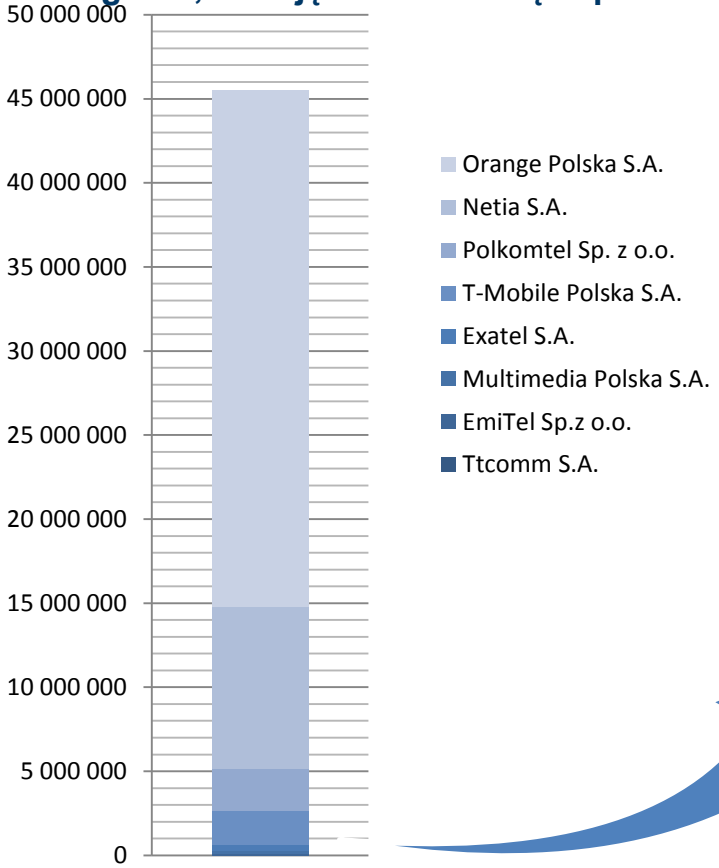
Główne ustalenia kontroli cd.

7. W Polsce nie funkcjonuje krajowy system reagowania na incydenty komputerowe, a administracja państwowa nie dysponuje wiedzą na temat skali i rodzaju incydentów występujących w cyberprzestrzeni.

   Czynności z zakresu reagowania na incydenty są realizowane przez funkcjonujące niezależnie od siebie zespoły CERT, nie posiadające wystarczających zasobów oraz umocowania prawnego. Brak jest CERTu narodowego.

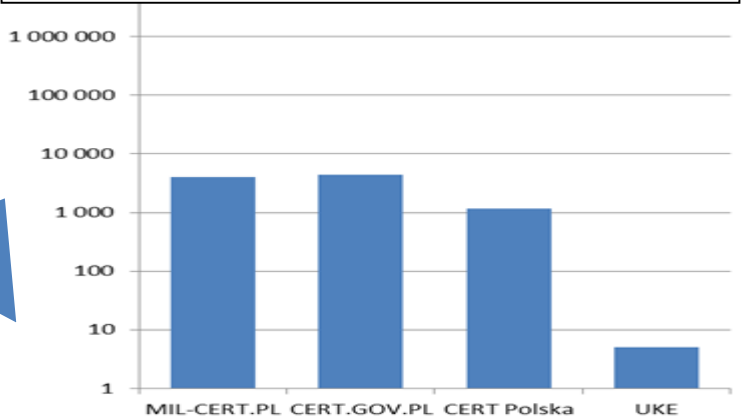
   Minister Administracji i Cyfryzacji, który odpowiada za koordynację krajowego systemu reagowania na incydenty komputerowe, nie realizował żadnych zadań w tym zakresie.

Zestawienie szacunkowej liczby incydentów w sieciach przedsiębiorców telekomunikacyjnych, zgłoszeń o incydentach przekazanych do UKE oraz incydentów obsłużonych przez poszczególne, objęte kontrolą państwowe zespoły CERT (za okres 1 roku):



Zsumowane na wykresie incydenty w sieciach przedsiębiorców telekomunikacyjnych dotyczyły adresów internetowych obsługiwanych przez te podmioty, zainfekowanych złośliwym oprogramowaniem, wykorzystywanych:

- **jako elementy składowe botnetów – 55%;**
- **do przeprowadzania ataków DDos – 43%;**
- **w innych celach (np. phishing) – 2%.**



Główne ustalenia kontroli cd.

8. Tworzone w Polsce plany reagowania kryzysowego, w tym Krajowy Plan Zarządzania Kryzysowego, nie uwzględniały zagrożeń związanych z cyberprzestrzenią.

9. Podmioty państwowe nie podejmowały działań w celu ustanowienia wymogów w zakresie bezpieczeństwa cyberprzestrzeni. Nie były również realizowane ustawowe zadania dotyczące kontroli bezpieczeństwa systemów teleinformatycznych.

Główne ustalenia kontroli cd.

10. Podmioty państwowe nie współpracowały w zakresie ochrony cyberprzestrzeni RP – nie wdrożono skutecznych mechanizmów koordynacji działań w tym obszarze.

11. Podmioty państwowe nie organizowały ćwiczeń dotyczących bezpieczeństwa teleinformatycznego, służących weryfikacji i doskonaleniu procedur reagowania w przypadku cyberataków.

12. Nie zostały podjęte działania, mające na celu budowę ogólnokrajowego systemu wczesnego ostrzegania przed zagrożeniami w sieci Internet.

Główne ustalenia kontroli cd.

13. Nie wypracowano założeń systemu działań edukacyjnych, podnoszącego kwalifikacje w zakresie bezpieczeństwa IT oraz zwiększającego świadomość zagrożeń.

14. Realizowane przy udziale środków publicznych, nieliczne projekty naukowo-badawcze związane z ochroną cyberprzestrzeni nie miały praktycznego zastosowania, były niespójne programowo oraz ukierunkowane na realizację interesów beneficjentów projektów.

Wnioski i propozycje działań naprawczych

Ustalenia kontroli wskazują na konieczność bezzwłocznego podjęcia skoordynowanych, systemowych działań prowadzących do wdrożenia realnych mechanizmów ochrony cyberprzestrzeni RP.

W celu wyeliminowania przeszkód, które sparaliżowały aktywność państwa w tym zakresie w latach 2008-2014, konieczne jest bezpośrednie zaangażowanie Rady Ministrów i Prezesa Rady Ministrów.

Niezbędne jest również wdrożenie mechanizmów współpracy podmiotów prywatnych i państwowych oraz zapewnienie odpowiedniego finansowania.

Wnioski i propozycje działań naprawczych cd.

Najważniejsze działania naprawcze, powinny obejmować:

1. **Skoncentrowanie działań związanych z ochroną cyberprzestrzeni na zapewnieniu bezpieczeństwa teleinformatycznej infrastruktury krytycznej państwa.**
2. **Uchwalenie odrębnej ustawy określającej strukturę krajowego systemu ochrony cyberprzestrzeni.**
3. **Stworzenie systemu finansowania zadań związanych z ochroną cyberprzestrzeni.**

Wnioski i propozycje działań naprawczych cd.

4. Przyjęcie przez Radę Ministrów narodowej strategii zarządzania zagrożeniami występującymi w cyberprzestrzeni.
5. Wdrożenie krajowego systemu reagowania na incydenty komputerowe, obejmującego m.in. obowiązki w zakresie raportowania o incydentach.
6. Opracowanie procedur reagowania kryzysowego w sytuacji zagrożeń infrastruktury państwa spowodowanych zdarzeniami występującymi w cyberprzestrzeni.
7. Wyznaczenie krajowego organu koordynującego działania w zakresie ochrony cyberprzestrzeni, będącego jednocześnie CERTem narodowym.

Uprawnienia NIK

NIK nie ma uprawnień w zakresie egzekwowania i nadzoru nad wykonaniem wniosków pokontrolnych. Możemy oddziaływać za pośrednictwem wnioskodawców kontroli (np. Sejm, Prezydent) oraz kierownictwa jednostek nadrzędnych nad kontrolowanymi.

NIK gromadzi tylko informacje od poszczególnych podmiotów na temat realizacji wniosków pokontrolnych.

Jedynym, wiarygodnym mechanizmem weryfikacji tych informacji jest przeprowadzenie kontroli sprawdzającej.

Reakcja na ustalenia kontroli

Kierownicy siedmiu jednostek objętych kontrolą zgodzili się z wnioskami wynikającymi z kontroli NIK.

Podmiotem, który początkowo zanegował ustalenia kontroli i odmówił wykonania wniosków pokontrolnych był Minister Administracji i Cyfryzacji.

Minister skorzystał z przysługującego mu prawa złożenia zastrzeżeń do wystąpienia pokontrolnego.

Stanowisko MAiC

W zastrzeżeniach Minister starał się wykazać, że:

- **obowiązujące przepisy nie nakładają na niego zadań w zakresie ochrony cyberprzestrzeni;**
- **uzasadnione jest wstrzymanie działań związanych z budową krajowego systemu ochrony cyberprzestrzeni do czasu przyjęcia Dyrektywy NIS;**
- **zadania w zakresie ochrony cyberprzestrzeni mogą być realizowane selektywnie, w oparciu o „dobrowolną, owocną współpracę między jednostkami administracji" oraz „bezkosztowo".**

Zastrzeżenia, zgłoszone przez Ministra zostały jednogłośnie odrzucone przez Kolegium NIK.

Stanowisko MAiC cd.

Zmiana stanowiska Ministra nastąpiła po otrzymaniu zbiorczej informacji o wynikach kontroli, która pokazała nieprawidłowości dotyczące MAiC w szerszym kontekście, uwzględniającym uwarunkowania realizacji zadań podmiotów państwowych związanych z ochroną cyberprzestrzeni.

Minister Administracji i Cyfryzacji w dalszym ciągu nie dysponuje jednak zasobami (kadrowymi, finansowymi, technicznymi), ani umocowaniem prawnym pozwalającymi na efektywną realizację zadań.

Monitorowanie efektów kontroli

Pół roku po zakończeniu kontroli, NIK wystąpiła do wszystkich jednostek nią objętych o przekazanie informacji o działaniach zrealizowanych w wyniku kontroli oraz o sposobie wykorzystania wniosków i uwag Izby.

Analiza odpowiedzi wykazała, że na dzień dzisiejszy w kontrolowanym obszarze wystąpiły tylko pojedyncze, pozytywne zmiany.

Wartość dodana kontroli:

- podjęcie przez ABW działań w celu znaczącej rozbudowy potencjału związanego z reagowaniem na incydenty;
- powołanie w Policji wewnętrznego zespołu CERT;
- zintensyfikowanie działalności edukacyjnej Prezesa UKE w zakresie informowania o zagrożeniach związanych z korzystaniem z Internetu oraz rekomendowanych środkach ochronnych;
- powoływanie przez podmioty administracji pełnomocników ds. bezpieczeństwa cyberprzestrzeni oraz tworzenie kanałów wymiany informacji i procedur reagowania w sytuacji wystąpienia incydentów.

Skutki kontroli

Przeprowadzona kontrola nie spowodowała natomiast istotnych, pozytywnych zmian w zakresie działalności podmiotów państwowych związanych z ochroną cyberprzestrzeni.

Nie został wyeliminowany żaden z kluczowych czynników paraliżujących aktywność państwa w tym obszarze.

Podejmowane obecnie działania, stanowią „kopię” wcześniejszych, nieskutecznych prac związanych z przygotowaniem „Polityki ochrony cyberprzestrzeni Rzeczypospolitej Polskiej” z lat 2008-2013.

Skutki kontroli cd.

Podmioty państwowe nie współpracują w zakresie ochrony cyberprzestrzeni RP, a podjęte przez nie działania w ramach realizacji wniosków NIK, skupiają się w przeważającej mierze na bezpieczeństwie własnych systemów teleinformatycznych.

Minister Administracji i Cyfryzacji nie zrealizował dotychczas żadnego z wniosków skierowanych do niego w wystąpieniu pokontrolnym oraz w dalszym ciągu nie sprawuje realnej koordynacji działań innych podmiotów zaangażowanych w ochronę cyberprzestrzeni.

Zamiast podsumowania

Czas na działanie…

Dziękuję za uwagę!